CYBERVSI

Web Application VAPT Report

Illustrative security assessment deliverable

SAMPLE / FICTIONAL

Target: Acme Portal (portal.demo.invalid)

Assessment window: 08-12 September 2026

Report date: 18 September 2026

Classification: Public sample

CONNECT@CYBERVSI.COM

Executive Summary

Assess a fictional customer portal for common application security weaknesses and provide prioritized, reproducible remediation guidance.

This sample presents security findings as inputs to the organization’s risk-management process. Business impact and remediation priority should be adjusted using the owner’s threat model, data sensitivity, and operating context.

Risk overview

Severity	Count	Recommended handling
High	1	Prioritize before the next production release
Medium	1	Plan remediation in the current engineering cycle
Low	1	Address through scheduled security hardening

Priority actions

1. Restrict the highest-risk attack path.
2. Apply the recommended configuration or code correction.
3. Review related components for the same root cause.
4. Retest and record closure evidence.

Assessment Parameters

Item	Sample detail
Objective	Assess a fictional customer portal for common application security weaknesses and provide prioritized, reproducible remediation guidance.
Scope	Acme Portal (portal.demo.invalid)
Approach	Time-boxed black-box and authenticated testing. Manual validation was supported by security tooling; scanner output alone was not treated as a confirmed finding.
Test accounts	Two fictional standard-user roles and one read-only administrative role
Limitations	No source-code review, social engineering, denial-of-service, persistence, destructive actions, or third-party infrastructure testing
Standards reference	OWASP WSTG v4.2, NIST SP 800-115, PCI SSC Penetration Testing Guidance, and FIRST CVSS v3.1

Rules of engagement

Testing was authorized only for the listed fictional targets during the stated window. Stop conditions included service instability, evidence of access to out-of-scope data, or contact from the designated incident owner. Evidence collection was minimized and credentials were not retained in the report.

Testing Coverage

Test ID	Control area	Result
WSTG-INFO	Information gathering and attack-surface mapping	Completed
WSTG-ATHN	Authentication testing	Completed
WSTG-ATHZ	Authorization testing	Finding raised
WSTG-SESS	Session management testing	Finding raised
WSTG-INPV	Input validation testing	No finding
WSTG-BUSL	Business-logic testing	No finding
WSTG-CLNT	Client-side testing	Finding raised
WSTG-CONF	Configuration and deployment testing	Completed

Result definitions

Completed means the planned checks were performed. Finding raised means at least one validated issue is documented. No finding means no issue was confirmed within the assessment constraints; it does not guarantee absence of vulnerabilities. Not tested must be explained in the limitations section.

Findings Summary

ID	Finding	Severity	CVSS
WEB-001	Broken object-level authorization in invoice export	High	6.5
WEB-002	Sessions remain active after password reset	Medium	5.6
WEB-003	Permissive framing policy	Low	N/A

Severity approach

CyberVSI reports the CVSS v3.1 Base score and vector where the framework is appropriate. Configuration and defense-in-depth observations may be marked N/A instead of forcing a misleading score. Technical severity is an input to risk assessment; the system owner should apply threat, asset criticality, data sensitivity, compensating controls, and regulatory context before accepting business risk.

Broken object-level authorization in invoice export

HIGH	CVSS 3.1 6.5	WEB-001

Classification	CWE-639 | OWASP A01:2021 | WSTG-ATHZ-04
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Affected asset

portal.demo.invalid/api/invoices/{id}/export

Description

The export handler trusts a user-controlled invoice identifier and does not enforce tenant ownership after authenticating the requester.

Business impact

A standard authenticated user could read another tenant’s invoice, exposing billing and customer information. The sample did not test bulk enumeration or records outside the agreed test dataset.

Reproduction and fictional evidence

```
1. Sign in as tenant-alpha.test. 2. Request owned invoice INV-1001: 200 OK. 3. Replace the identifier with tenant-beta invoice INV-1042. 4. Response: 200 OK; customer name and line items returned. Sensitive values are redacted.
```

Recommended remediation

Enforce object-level authorization in the service layer for every read and export. Resolve tenant identity from the trusted session, reject cross-tenant identifiers with a consistent response, review sibling endpoints, and add automated negative authorization tests.

Validation: Re-test the affected flow after the fix and confirm that equivalent endpoints enforce the same control.

Sessions remain active after password reset

MEDIUM	CVSS 3.1 5.6	WEB-002

Classification	CWE-613 | OWASP A07:2021 | WSTG-SESS-06
CVSS vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N

Affected asset
portal.demo.invalid account and session services

Description
The password-reset flow changes the credential but does not revoke existing web sessions or refresh tokens.

Business impact
A previously stolen session may remain usable after account recovery. Exploitation requires an attacker to already possess a valid session token.

Reproduction and fictional evidence

```
1. Create sessions A and B for the same test account. 2. Reset the password using session A. 3. Replay session B six minutes later. 4. GET /api/profile returned 200 OK. No privileged actions were attempted.
```

Recommended remediation
Revoke active sessions and refresh tokens when a password is reset. Rotate the current session, require reauthentication for sensitive changes, expose session management to users, and alert on security-sensitive account recovery events.

Validation: Re-test the affected flow after the fix and confirm that equivalent endpoints enforce the same control.

Permissive framing policy

LOW	CVSS N/A	WEB-003

Classification	CWE-1021 | WSTG-CLNT-09
CVSS vector	Not assigned - defense-in-depth configuration

Affected asset
portal.demo.invalid

Description
The Content-Security-Policy permits framing by any origin through frame-ancestors *.

Business impact
An attacker-controlled site could frame the application and attempt UI redressing. The sample did not demonstrate a complete harmful action because state-changing functions required an additional confirmation.

Reproduction and fictional evidence

```
Response header observed on /dashboard: Content-Security-Policy: default-src 'self'; frame-ancestors *
```

Recommended remediation
Set frame-ancestors to 'none' unless framing is required. If required, list only trusted origins. Retain anti-CSRF controls and verify sensitive actions cannot be completed through an embedded context.

Validation: Re-test the affected flow after the fix and confirm that equivalent endpoints enforce the same control.

Remediation Roadmap

Timeframe	Recommended action	Owner
0-7 days	Contain the high-risk path and confirm monitoring coverage	Application or infrastructure owner
8-30 days	Implement durable fixes and review equivalent components	Engineering and security
31-60 days	Complete hardening items, retest, and retain closure evidence	Security governance

Retest expectations

A retest should confirm that the original proof no longer succeeds, the root cause is corrected, and the fix does not introduce a regression. Residual risk and accepted exceptions should be documented by the system owner.

Appendix

Methodology references

OWASP Web Security Testing Guide v4.2: https://wstg.owasp.org/v4.2/
NIST SP 800-115: https://doi.org/10.6028/NIST.SP.800-115
FIRST CVSS v3.1: https://www.first.org/cvss/v3.1/specification-document
PCI SSC Penetration Testing Guidance:
https://listings.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf

Sample data notice

All company names, systems, domains, IP addresses, user accounts, timestamps, request fragments, findings, and evidence in this document are fictional. This document demonstrates the intended CyberVSI reporting format and is not proof of a completed assessment.

CyberVSI
connect@cybervsi.com
service.cybervsi.com